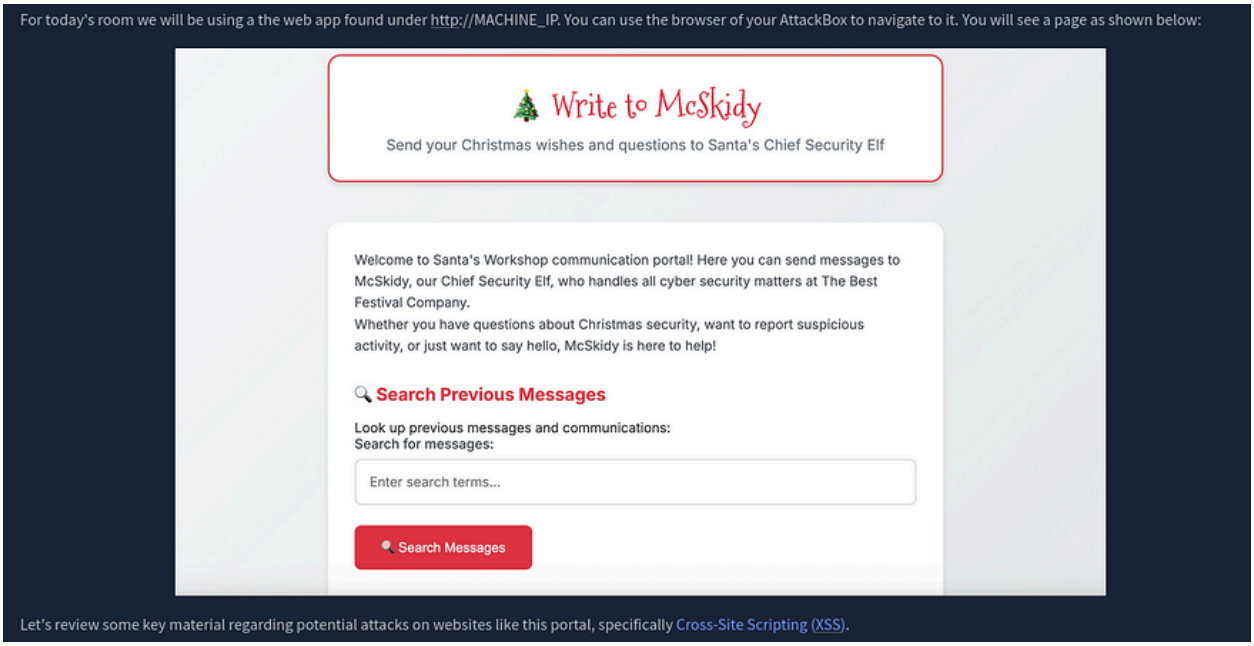
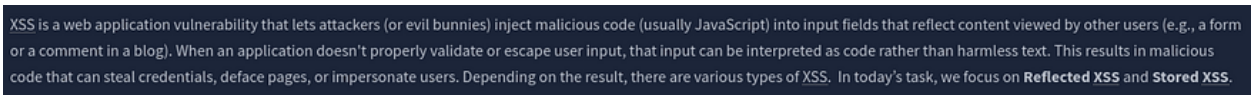
AoC XSS



Press enter or click to view image in full size



Cross-Site Scripting (XSS) is a web app vulnerability that lets evil bunnies inject malicious code into the input fields the reflect content viewed by other users. When the app doesn't properly validate user input, the input gets interpreted as code instead of just text. This ends up making malicious code that can steal credentials, deface pages, and impersonate users. There a different types of XSS, but this room will go over Reflected XSS and Stored xss.

Press enter or click to view image in full size

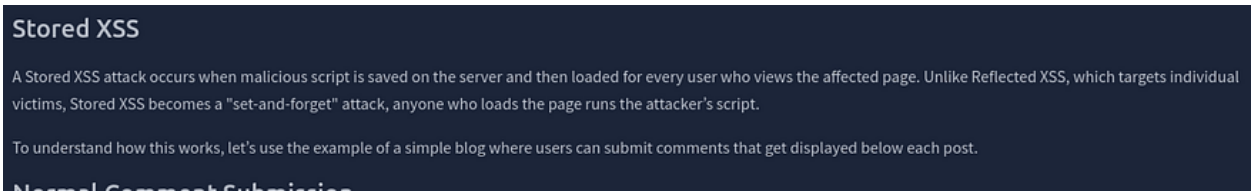


So whenever the function immediately projects a response, without validation.

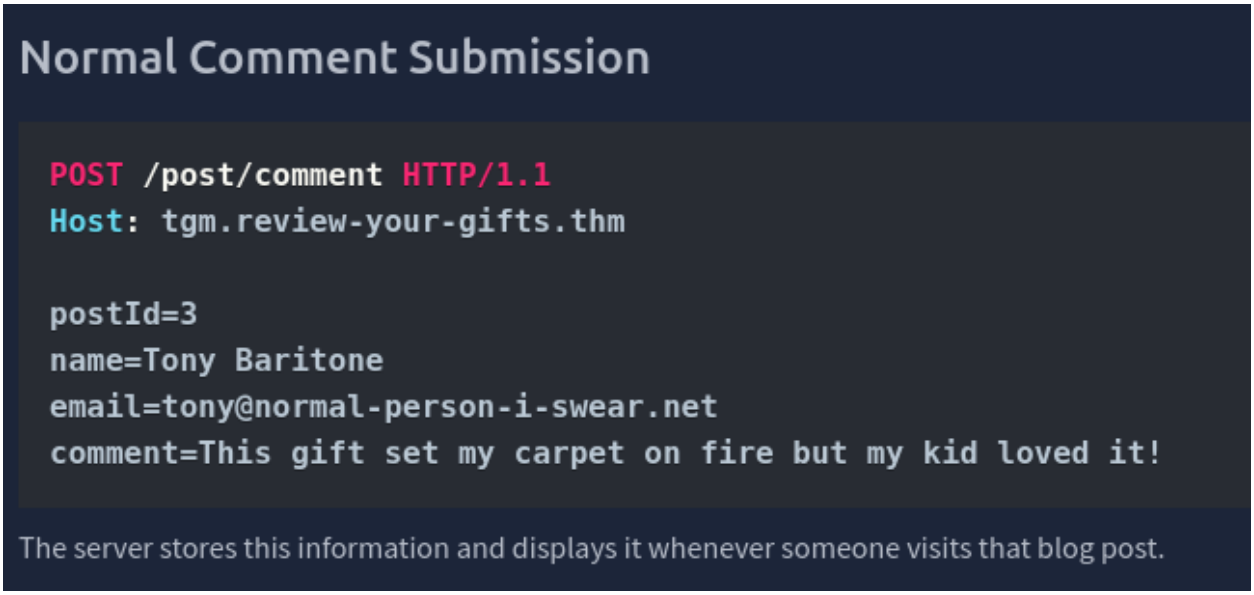
So if normally to view a webpage, you use the first URL, but you modify that URL, and have someone else click on that link, the person will then load the webpage, plus whatever extra malicious code you added to the URL.

This is commonly done in phishing to trick users to click a malicious link.

Press enter or click to view image in full size

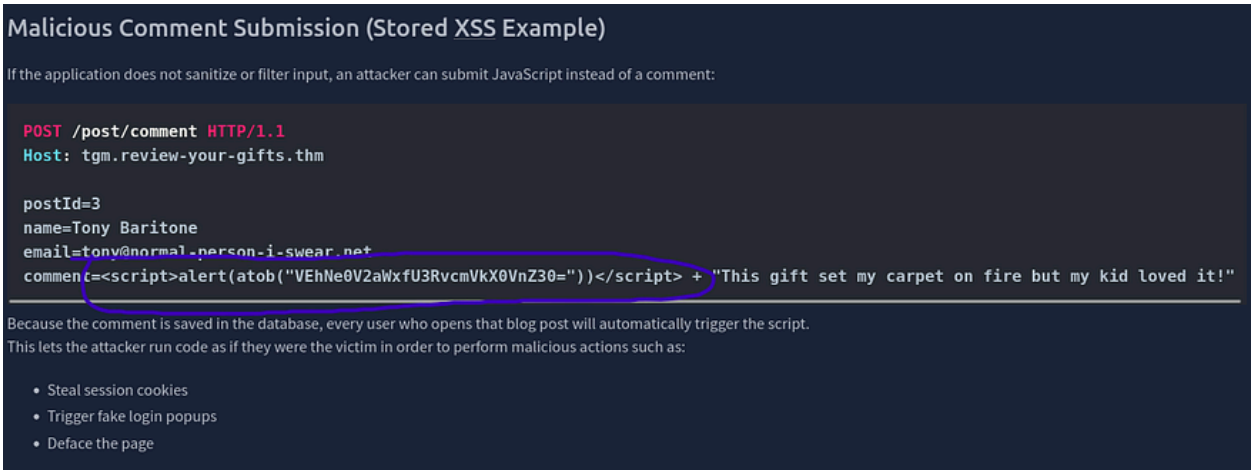


Stored XSS, instead of affecting one person at a time, will actually save onto the server itself. So now, every single person from then on that loads that page, will run the attacker's script.



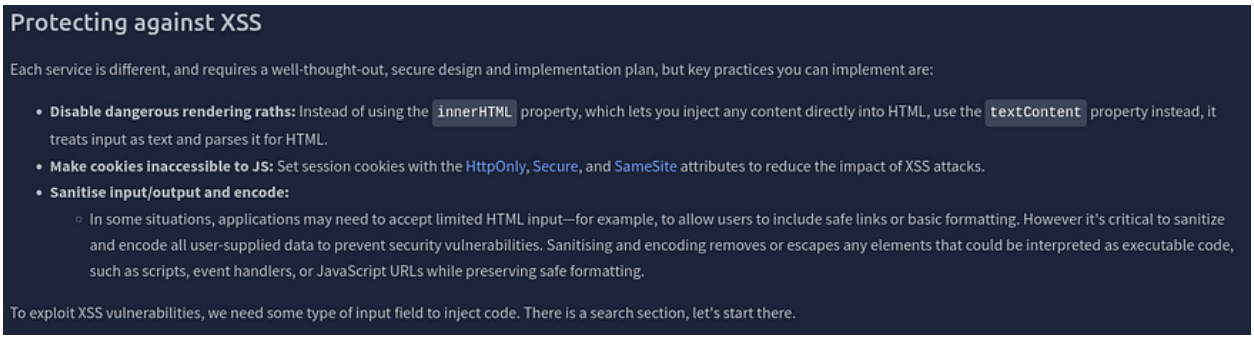
So once this http request is made, the server stores this information, and loads for anyone that goes to that blog post.

Press enter or click to view image in full size



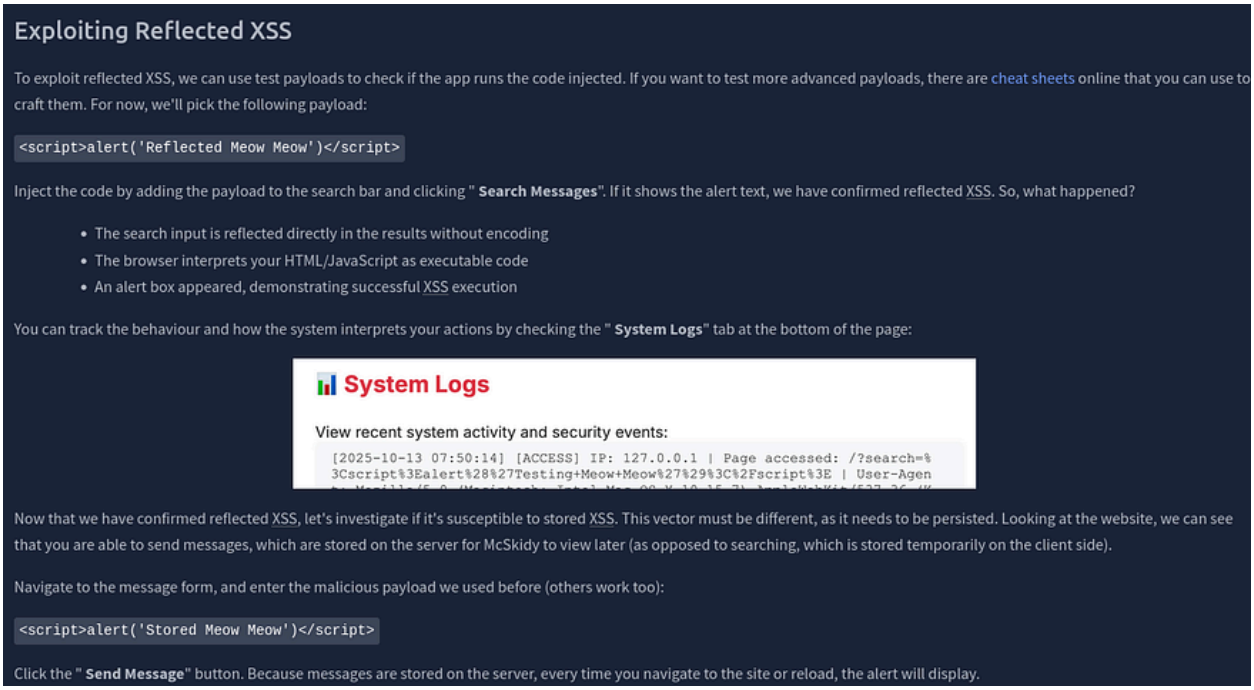
So there, when the http post request is sent to the server, instead of just being normal text for the comment, the attackers put that JavaScript instead, which will then execute every time someone loads that page.

Press enter or click to view image in full size



To protect against XSS you can disable dangerous rendering paths, make cookies inaccessible to JS, and sanitise input/output and encode it.

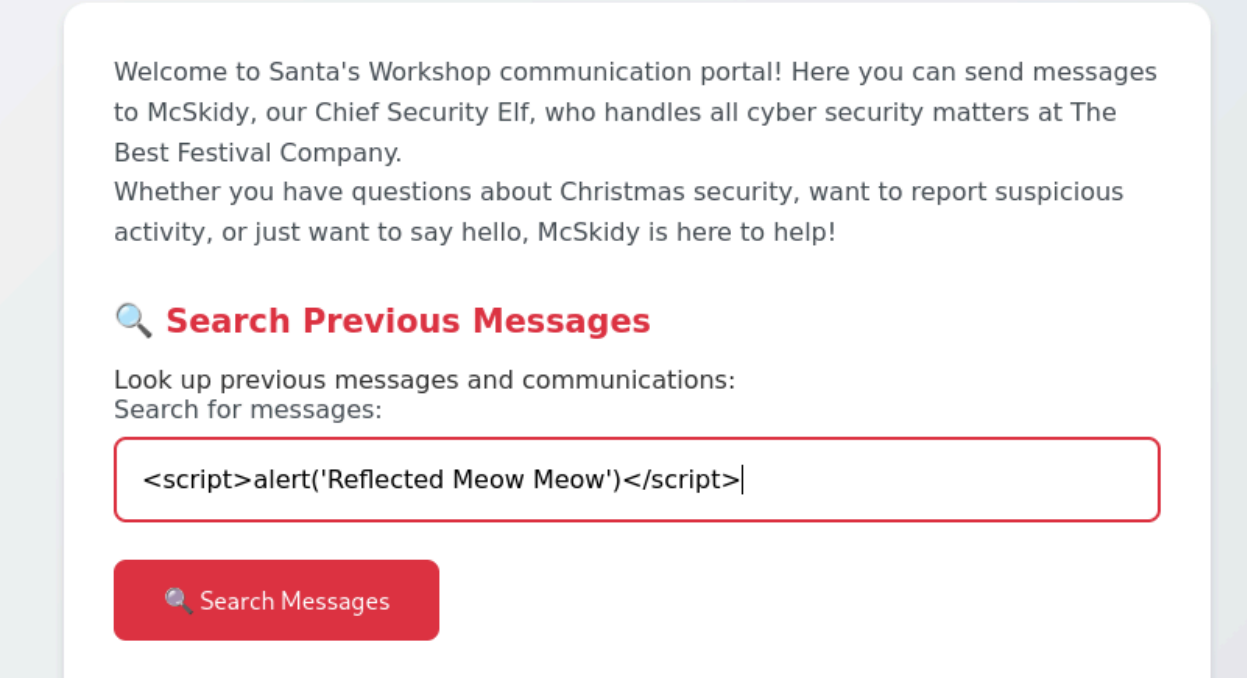
Press enter or click to view image in full size



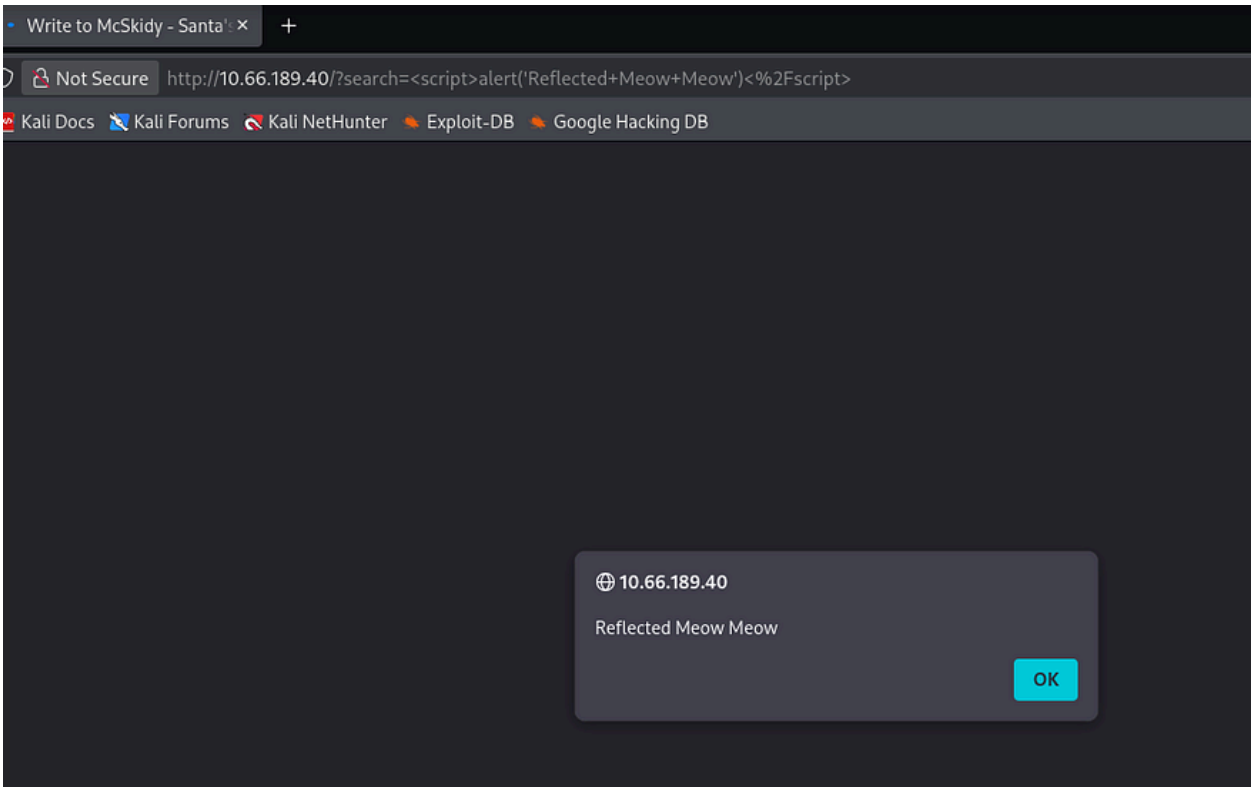
To test and see if a web app is vulnerable to XSS, we need an input field.

From there, we can test out payloads and see if the app runs the code we're injecting.

Press enter or click to view image in full size



Press enter or click to view image in full size



After we hit the search messages button, this is what the page turns into. This shows that the JavaScript we entered, to show an alert saying “Reflected Meow Meow” and ran immediately.

The search input was reflected directly.

The browser interpreted the HTML/JavaScript as executable code.

An alert box appeared, showing successful XSS execution.

The answers to the 2 questions are found by following along above.